FICTIONAL PROTOTYPE · Fictional organisation · Test-fixture figures, not an approved score · Not a certified paid report

MK FRAUD INSIGHTS

ESSENTIAL FRAUD READINESS REPORT

On its own answers, the organisation reports the controls in place for 37 of the 49 fraud scenarios that apply and a control reported as a gap in 10.

CALCULATED TEST RESULT
78.5 of 100, test fixture

UNRESOLVED INCONSISTENCIES
None found

PROVISIONAL MANAGEMENT INTERPRETATION
10 with a control reported as a gap

APPROVED READINESS CONCLUSION
None issued

PREPARED FOR

Fictional Owner-Managed Firm

Assessment reference · FX-P4

Assessment date · 12 November 2026

CONFIDENTIAL · PREPARED FOR THE MANAGEMENT OF FICTIONAL OWNER-MANAGED FIRM

WHAT DOES THE ASSESSMENT ESTABLISH?

What the assessment establishes

CALCULATED TEST RESULT

78.5 of 100, test fixture

From a research simulation of the draft method, kept for traceability. It is not a score, a maturity band or a readiness level.

UNRESOLVED INCONSISTENCIES

None found

None found in the 1 pair of answers compared. Most related practices were not asked, so this is not a finding that every answer is consistent.

PROVISIONAL MANAGEMENT INTERPRETATION

10 with a control reported as a gap

On its own answers, the organisation reports the controls that stop the scenario in place for 37 of the 49 fraud scenarios that apply, and a control reported as a gap in 10. This reads self-reported answers; nothing has been tested.

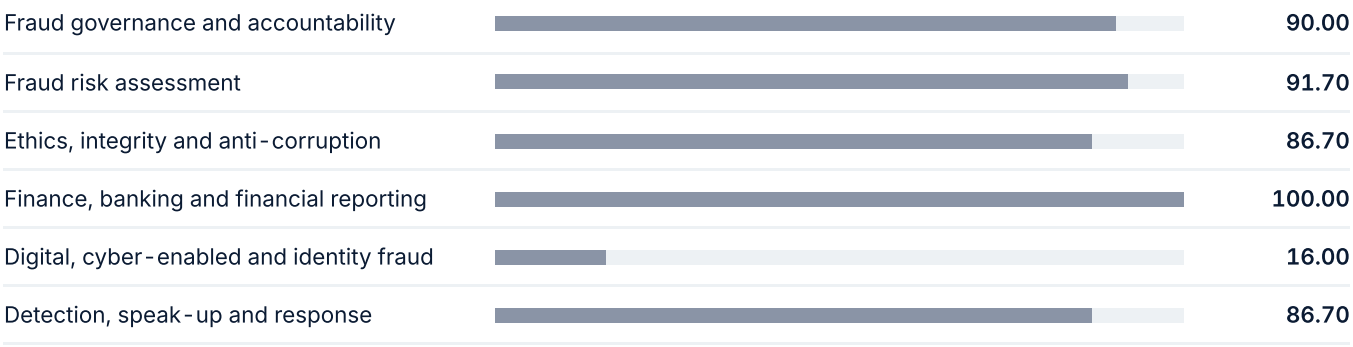
APPROVED READINESS CONCLUSION

None issued

MK has not approved a readiness method, band or threshold, so no readiness conclusion is drawn from the answers or from the calculated test result.

49 fraud scenarios apply to the organisation, and the method does not ask about 2 more at its size. The core and breadth stages are complete: 49 of the 49 confirmations that apply were answered, and no question is outstanding. Area figures below are calculated test results from the same research simulation, shown in the method's order; they are not scores and do not rank the areas.

Calculated area figures (test fixtures)



Areas in the method's order. Each figure is a calculated test result from a research simulation of the draft method: not a score, a band or a ranking.

WHAT DO THE ANSWERS SHOW?

What the answers show

PATTERN	ASSESSMENT SIGNALS	WHY IT MATTERS
Digital, cyber-enabled and identity fraud: 10 scenarios with a control reported as a gap	Multi-factor on all email **Not in place** Email never enough on its own **Not in place** Verification for calls, voice notes and video **Partly in place**	Most business email compromise starts with an account that has no multi-factor authentication. The area also has: a payment instruction received by email is acted on and a cloned voice or video instruction is obeyed, and 7 more in the register.
1 scenario: control in place, a related practice weaker	Training on joining **Partly in place**	Where the relationship has been reviewed, the related practice is a further defence and the reported control stands as given. Where it has not, nothing is concluded from it. Each pair is in the register.

> **THE PATTERN THAT MATTERS**
>
> Where a control was reported fully in place and a related practice of the same scenario weaker, the two answers were compared using MK's reviewed relationships: 1 pair in 1 scenario. 1 pair is a further defence and the reported control stands as given. Separately, 5 of 24 controls that can be cross-checked were asked one further question; these compare the organisation's own answers, are not tests of operation and change no figure.

WHICH FRAUD SCENARIOS DO THE ANSWERS POINT TO?

Fraud scenarios the answers point to

FRAUD SCENARIO	ASSESSMENT BASIS	POTENTIAL CONSEQUENCE	INTERRUPTION POINT	WHY IT IS INCLUDED
An email account is taken over A mailbox without strong sign-in is used to send or intercept payment instructions.	Multi-factor on all email **Not in place**	Most business email compromise starts with an account that has no multi-factor authentication.	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions	**Control not in place** The control that stops it is reported as a gap.
A payment instruction received by email is acted on Changed details or urgent payments are processed on the strength of an email.	Email never enough on its own **Not in place**	Acting on payment instructions received by email is how business email compromise succeeds.	Every payment, salary or urgent request received by email is confirmed through a separate, known channel	**Control not in place** The control that stops it is reported as a gap.
A cloned voice or video instruction is obeyed A caller who sounds or looks like a known person is believed.	Verification for calls, voice notes and video **Partly in place**	Voices and faces can be cloned, so only an agreed verification method holds.	An agreed method, such as a call-back on a known number, verifies every request made by phone, voice note or video	**Control partly in place** The control that stops it is reported as a gap.
A security compromise is not notified The Regulator and affected people are not told, so they cannot protect themselves.	Compromises reported as POPIA requires **Partly in place**	POPIA section 22 requires notification as soon as reasonably possible.	A procedure sets out who decides and who notifies the Information Regulator and the people affected, as POPIA requires	**Control partly in place** The control that stops it is reported as a gap.
A help desk reset hands an attacker access An impersonator persuades the help desk to reset a password or authenticator.	Help desk resets verified **Partly in place**	The method links it to social engineering of the IT help desk and takeover of staff accounts.	Every password or multi-factor reset is verified through a route the caller does not control	**Control partly in place** The control that stops it is reported as a gap.

Included: every scenario whose answers must be settled or clarified (up to three), then one scenario with a control reported as a gap from each area, in the method's order, up to five in all. Inclusion and order are not a ranking: MK has not approved a method for rating fraud risks, and every scenario is in the register.

HOW COULD THESE SCENARIOS OCCUR?

How these scenarios could occur here

An email account is taken over

A mailbox without strong sign-in is used to send or intercept payment instructions › Multi-factor on all email not in place › Takeover of staff accounts

A mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication. Here, email accounts are protected by passwords only.

Interrupted by: Until the control operates, the IT lead checks new cases by hand. The target: multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.

Warning signs: Takeover of staff accounts · Business email compromise and payment redirection

A payment instruction received by email is acted on

Changed details or urgent payments are processed on the strength of an email › Email never enough on its own not in place › Business email compromise and payment redirection

Changed details or urgent payments are processed on the strength of an email. Acting on payment instructions received by email is how business email compromise succeeds. Here, payment changes received by email are acted on as received.

Interrupted by: Until the control operates, the chief financial officer checks new cases by hand. The target: an organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.

Warning signs: Business email compromise and payment redirection

A cloned voice or video instruction is obeyed

A caller who sounds or looks like a known person is believed › Verification for calls, voice notes and video partly in place › Deepfake voice and video impersonation of executives and staff

A caller who sounds or looks like a known person is believed. Voices and faces can be cloned, so only an agreed verification method holds. Here, some staff check unusual requests, depending on their own judgement.

Interrupted by: Until the control operates, the chief financial officer checks new cases by hand. The target: an agreed method, such as a call-back on a known number or a code word, verifies any request made by phone, voice note or video; it applies to everyone, including executives, and staff know they are expected to use it.

Warning signs: Deepfake voice and video impersonation of executives and staff

These are illustrative exposure mechanisms for an organisation with the controls it reported. They are not allegations that any event has occurred, and their order is not a ranking.

WHAT SHOULD MANAGEMENT ADDRESS?

Management matters requiring attention

MANAGEMENT OUTCOME	WHY NOW	ACCOUNTABLE	WHAT GOOD LOOKS LIKE
Name an owner for each area and decide the order of work	MK has not approved a method for rating fraud risks, so this report does not rank the 10 scenarios with a gap. Their order is management's decision, made on explicit factors.	Chief executive	Each area has one accountable executive, and the order of work is recorded with its factors: the control's position, whether money or goods can leave, activity volume, detective cover and controls shared.
Put in place: multi-factor on all email	It stops the scenario where an email account is taken over. The control is reported as not in place.	IT lead	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
Put in place: email never enough on its own	It stops the scenario where a payment instruction received by email is acted on. The control is reported as not in place.	Chief financial officer	An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.
Put in place: verification for calls, voice notes and video	It stops the scenario where a cloned voice or video instruction is obeyed. The control is reported as partly in place.	Chief financial officer	An agreed method, such as a call-back on a known number or a code word, verifies any request made by phone, voice note or video; it applies to everyone, including executives, and staff know they are expected to use it.
Put in place: compromises reported as POPIA requires	It stops the scenario where a security compromise is not notified. The control is reported as partly in place.	IT lead	A procedure sets out who decides, who notifies the Information Regulator through its eServices portal and the people affected, and how quickly, as section 22 of POPIA requires.
Put in place: help desk resets verified	It stops the scenario where a help desk reset hands an attacker access. The control is reported as partly in place.	IT lead	Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.

Listed in the order the work depends on: facts and decisions first, then the controls for the scenarios above, in the method's area order. The list is not a risk ranking.

WHAT COULD THE FIRST 90 DAYS COVER?

Proposed stages for the first 90 days

These are proposed planning stages for starting the work, not deadlines, contractual dates or estimates. Each window shows when a stage could begin once what it depends on is known and decided. How long a control takes to design, put in place and show to be operating depends on the organisation, and management sets its own dates.

30 days, proposed: establish the facts and owners

PROPOSED WINDOW · 0–30 DAYS

Answers that conflict are settled, open questions and outstanding answers are answered, and each area with open scenarios has an accountable executive.

Name the accountable executive for each area, and decide the order of work using explicit factors. — Chief executive

Named executives and a recorded order of work, with the factors behind it.

Complete when: Every open scenario is selected, deferred with a reason or accepted at the right level.

60 days, proposed: approve designs and begin

PROPOSED WINDOW · 31–60 DAYS

Approved designs exist for the controls management selected, and the first are being put in place.

Approve the target design for each selected control, using the target practice, records and measure in the register, and begin putting the first designs in place. — Each accountable executive

Approved designs, each with an owner and the records it will keep.

Complete when: Each selected control has an approved design and a named owner.

90 days, proposed: start operating and report

PROPOSED WINDOW · 61–90 DAYS

The first approved controls have started operating and the oversight body has the status of every open scenario. Whether a control works is known only after its first full cycle, which for many controls ends after 90 days.

Start operating the approved designs, and begin each control's first full operating cycle. — Each process owner

A start date and an operating record for each control.

Complete when: Each control has started operating; its success measure is checked when its first full cycle ends.

Report the status of each open scenario to the owners. — Chief executive

A one-page status per scenario: owner, controls in place, controls outstanding, next step.

Complete when: The status is received and minuted.

HOW WILL MANAGEMENT KNOW THE WORK IS TAKING EFFECT?

What to check at the 90-day point

MEASURE	POSITION TODAY	90-DAY EXPECTATION
Multi-factor on all email	Email accounts are protected by passwords only.	Design approved and operating started. After its first full cycle: at the end of the period, the email security report shows multi-factor authentication on every email account, including executives' and shared mailboxes, and any exception is approved and recorded.
Email never enough on its own	Payment changes received by email are acted on as received.	Design approved and operating started. After its first full cycle: all staff who act on payment or salary requests were briefed by the end of the period, and the most recent test found the rule followed in every case tested.
Verification for calls, voice notes and video	Some staff check unusual requests, depending on their own judgement.	Design approved and operating started. After its first full cycle: all staff who act on requests by phone, voice note or video were briefed by the end of the period, and the most recent test found the rule followed in every case tested, including requests that appeared to come from executives.
Open scenarios with a named owner and a decision	None recorded in the assessment (10 open).	Each selected, deferred with a reason or accepted at the right level.

Management conclusion

On its own answers, Fictional Owner-Managed Firm reports the controls in place for 37 of 49 fraud scenarios and a control reported as a gap in 10, across 1 area. MK has not approved a readiness method, so this report draws no readiness conclusion and does not rank fraud risks; the order of the remaining work is management's decision, and the supporting register lists every scenario, control and record behind this report.

This report is based on the organisation's own answers to the MK Fraud Readiness review, given by the respondent and the accountable functions named in it, and read against the draft review method, which MK has not yet approved. MK has not independently tested whether controls operate in practice, and no evidence was reviewed; evidence review is a separate Advisory service. The records named in this report are records management should maintain; MK has not requested or examined them. TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating.